Cyber news

1. https://redteamsecurity.com/

2.https://thehackernews.com/

3. https://www.bleepingcomputer.com/

4. https://cyberpress.org/

5. https://www.cisa.gov/

6. https://attack.mitre.org/

7. https://thedfirreport.com/

8. https://www.checkpoint.com/resources/

9.

1. Monitor and investigate various security alerts
2. Participate in SOC brainstorms and workshops
3. Cooperate with other teams to keep your company safe
4. Constantly learn and discover new attacks and defenses

Defenders who analyze attacks, stop breaches, and keep companies safe

Detection

1. Detect Vulnerabilities

2. Detect Unauthorized Activity

3. Detect Policy Violation

4. Detect Intrusion

Response

Support with Incident Response

All this SOC Setup Happens in

Ingernal SOC

MSSP(Managed Security Service Provider)

Brached Database

1. https://haveibeenpwned.com/

Languages fo the Log Query

1. SPL (Search Processing Language)
2. KQL (Kibana Query Language)
3. KQL (Kusto Query Language)
4. FQL (Falcon Query Language)

Main Focus

Detection

Response

USING

Security Solutions

Integrate

Company's Network

All Systems

Monitor

In One Centralized Location

Based on the severity

CIRT

Forensics

Threat Intel Expert

Threat Hunting Expert

CIRT Manager

Malware Analyst

SOC Architecture

Phase 1

Phase 2

Phase 3

Phase 4

EDR and SIEM agents (Forwarders,Beats)

For Collecting Telemetry from hosts and all devices in Org Network

SIEM (Kibana+ Logstash)

Aggregation , Correlating and trigger Alert

Analyst (search Tasters, Elasticsearch)

Alert handling

SOAR

Well-known alerts are handle by the SOAR by following the Playbooks or Workbooks

Analyzist

Take action on one by one

1. EDR host handling
2. SIEM
3. AD to disable compromised accounts

Create the orchestration in SORA

SOC(Security Operations Center)

People

Process

Technology

SOC Analyst

SOC Analyst

SOC Analyst

Security Engineer

Detection Engineer

Escalation Path

SOC Manager

CISO

Security solution centralize all the information of the devices and the application present in the network and automate the detection and response capabilities

Visibility/Logs

Network Security

Endpoint Security

Automation

SIEM

EPP

XDR

EDR

Firewalls

IDS/IPS

SOAR

Alert Triage

Reporting

Incident Response & Forensics

Determines the severity of the alert and help us prioritize

What happened

When

Where

who

Why

Harmful alerts are escalated to Higher Level Analysis as Tickets and Assigned to the relevant people

For

Response

Resolution

Some Malicious activities are critical

High-level teams initiate Incident Response

Detailed forensics activity may need to be performed

Concept and Lifecycle of the Alerts

Events To Alerts

Events : Every action in system is know as event know as Event Logs

Detection Engineer : writes rule to trigger the threat based on IOA ,IOC and Threat Intelligence

Security Solutions

Alert : Notification on suspicious event and it details

Alerts Handeling

Description

What action and where it happend: Rests

Verdict

Alert Properties

Date and Time

Assignee

Name

Status

severity

Alert Reporting

You aren't just saying "I think it's bad," You are saying "I know it's True Positive or Fales positive **because** I saw it and verified it with ?."

Alert Prioritization

Every SOC team has it Own Prioritization Rule and Ususaly Automatates them in the Security Solutions

Communication(S Place importen role in the whole process)

Alert escalation

Because the threat is real and requires deeper investigation, containment, or legal documentation that goes beyond the L1's authority.

Alert Triage

Stef Assign

Status Updateing to in Progress

Understand the Alrert

Escalate to L2

Yes

Do it need escalation ?

No

Status Update to Closed

Add your Alrert Comment

Fallow it

Yes

Make final verdict on the alert

Check for the Playbook

No

Investigate on the Security Solution

Attack Vectors

Humans As Attack Vectors

If Threat Actors traget Gatekeeper , Gate will opne as per Attacker need , Which is easy for them hard for defender.

Because

1. It is normal activity everyone.

2. No abnormal footprints left for detection.

3.We need to correlate all action he performed before and figure out origen then only we conclude that it is attacks .

Hacking humans is Know as Social engineering

This are most offten useing

1. Phishing Attack

2. Malware Downloads

3. Impersonating

4. Deepfakes

Systems As Attack Vectors

any physical server, virtual machine, Cloud Platforms

In a phishing attack, threat actors typically only gain access to the resources the compromised user is authorized to use—unless they perform **privilege escalation**. However, if the **system** itself is the target and is successfully breached, the attacker can gain full control, allowing them to manipulate the resource and impact all users who rely on it.

Attacks on System

Humans-led Attacks

Misconfiguration one of the most common issue

Penetration Testing

Vulnerability Scans

Configuration Audits

Vulnerabilities

Zero Day

After the Vulnerability is made Public

CVE (Common Vulnerabilities and Exposure)

Quaterntain or Continous Monitor until patch is available

Supply chain

Trusted Application executing unmted activities

Defending Humans

Mitigation

Detectinol SOC team will handel it !

Anti - Phishing Tools

Anti - Virus / EDR

Security Awareness Training and Detail Reporting methods

Defending the Systems

Mitigations

Any thing Beyond this will Handle By SOC team

Patch Management

Training for It

Network Protection

Anti-Virus Protection

Example

X doing or don Z activity on the Y

Decision depends on the

Assets and Identities

You will get information about the X and Y

Workbooks

Collection of instructions for handling different types of alerts (2)

Experience

Concludes the Verdict , escalation, alert status

Efficiency and Reliability of SOC is measured and it's Metrics

First Four Main Matrics

AC = Alerts Count

Measures

Total load on SOC team

FPR= False Positive Rate

Measures

Noise in the alerts max 30%

AEPr Alerts Escalation Rate

Measures

Experience of L1 , it should be 50% or below 20

TDR= Threat Detection Rate

Measures

Reliability of SOC team, it should be 100%

Triage Matrics

MTTD(Mean Time To Detect)

Time taken by tools and people(rise Alert for Events

MTTA(Mean Time To Acknowledge)

Acknowledge alert and start the investigation

MTTR(Mean Time To Respond/Remediate)

Total time take for stop attack or breach and Remediate from the MTTA+whole internal Process

Detection Methodologies

Detection Gap analysis (Threat Modelling)

Reactive

1. From recent incidents
2. Lessons Learns

Proactive

1. Following the ATT&CK map out the potential Threats

Data source Identification and Log Collation

Baseline Creation

Need to draft the Baseline which need the identify all devices running in the Organization

High level (system independent)

Technical(system dependent)

Log Collection

Once we figure out the Baseline of each device in organization. we start aggerating the events log from the EDR, forwarders, network monitors.

Writing Detection Rule

Based on the infrastructure setup and SIEM services detection rules need to be written. we use Sigma, Yara to write rules. We need to test and deploy.

EDR (End Point Detection and Responce)

What is it ?

It is the Security solution to protect the endpoint devices of Organation and indivisuals

Why it is need

Organation protect it's netwok using the Firewall, IDS,IPS ,segmentation of network etc. but when it is out of the it netwok like employees PC(BYOD) and the Remote work it is hard to protect them.

How it Works

IT is directly setup in the HOST devices but different from the Anti-Virus.

EDR Solutions

1. CrowdStrike Falcon

2. SentinelOne ActiveEDR

3. Microsoft Defender for Endpoints

4. OpenEDR

5. Symantec EDR

EDR Features

Visability

Detection

Responce

How EDR works

ERD Agents

ERD Agents

ERD Agents

ERD Agents

EDR Console

Data from the agents know as Telemetry

MITRE ATT&CK Maping

Detection

Mechine Learning Algorithum

IOC Matching

Behavioral Detection

Anomaly Detection

Artefacts Collection

Response

Host Isolation

Remote Access

Quarantine

Terminate Process

SIEM(Security Infromation and Event Management)

What is it ?

It colletes the Logs from the all devices in network

Why it is need

1. Numerous Log

2. For Centralization

3. Correlation Across Network

4. Logs Analysis

5. Overcome Formate Issues

How it Works

LOGS

Host-Centrics

Network-Centrics

Log Integration

Agent/Forwarder

Syslog

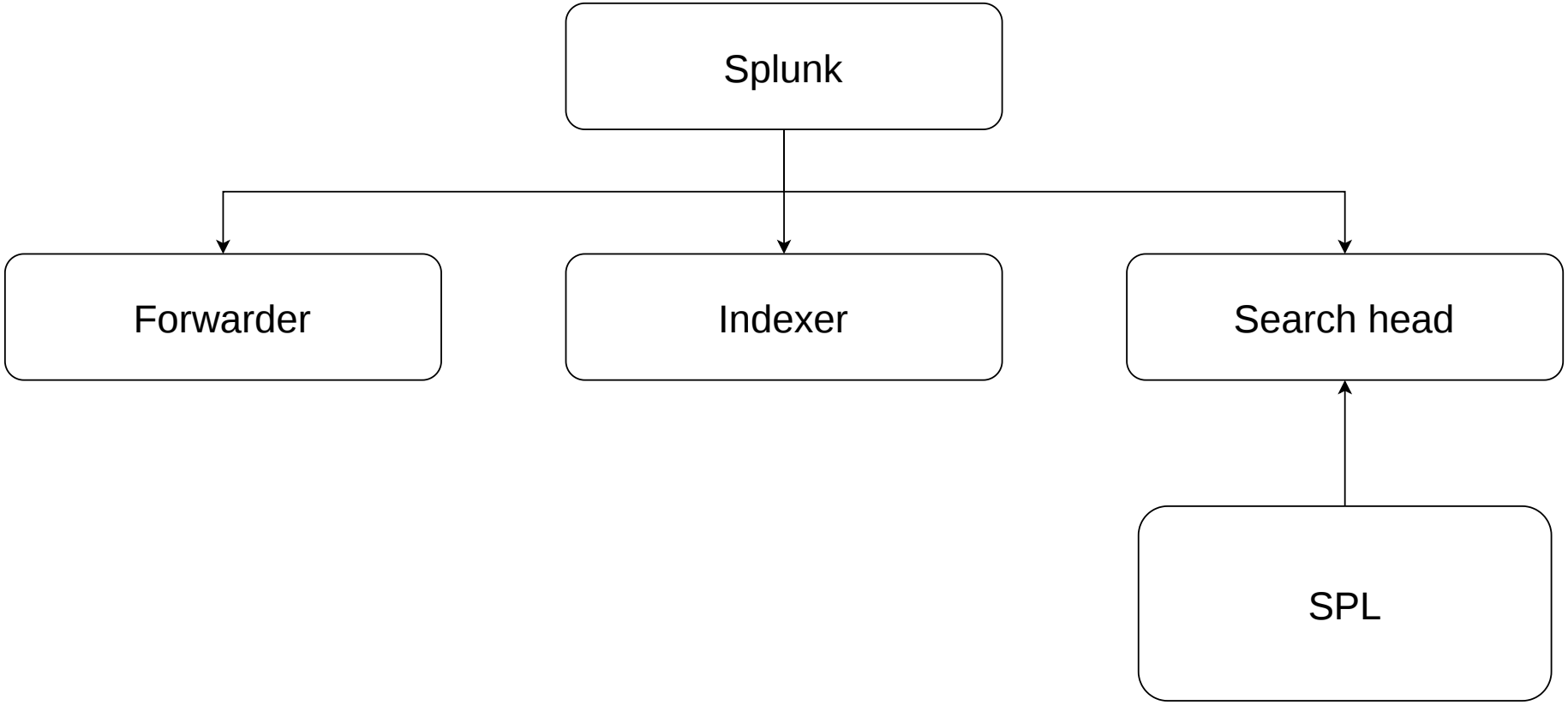
Manual Upload

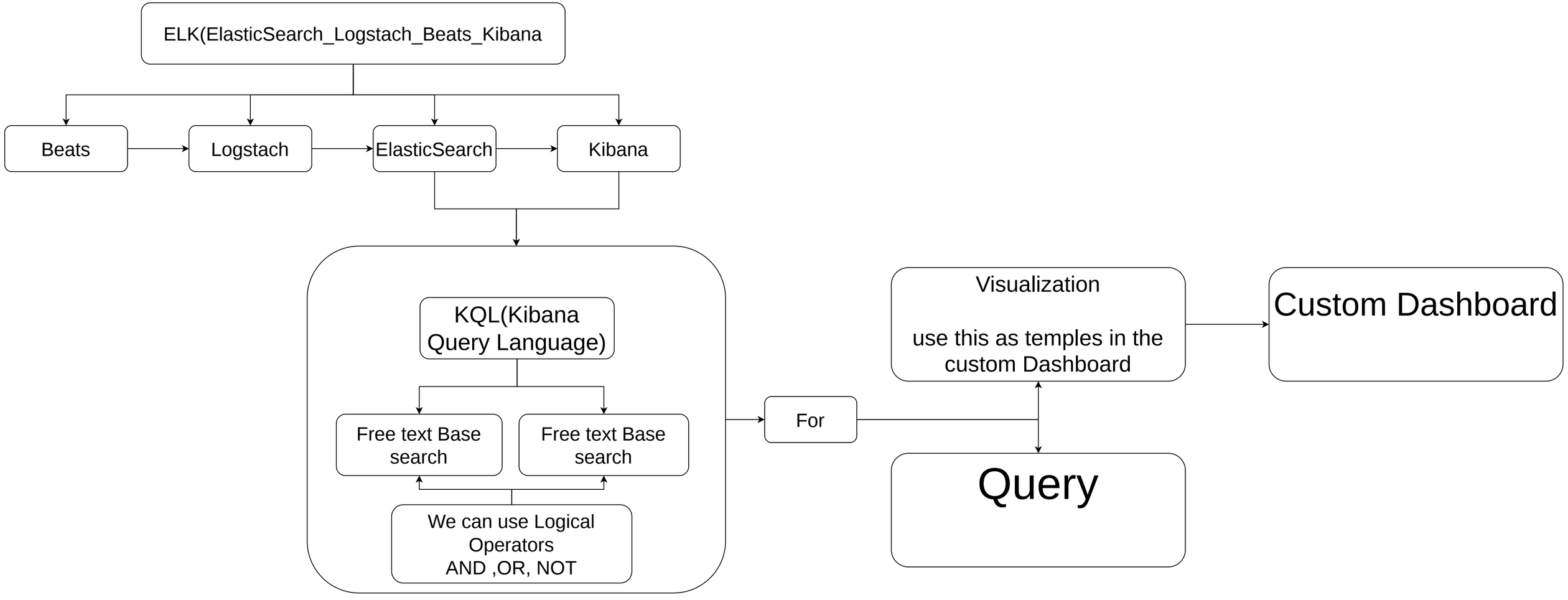
Port-Forwarding

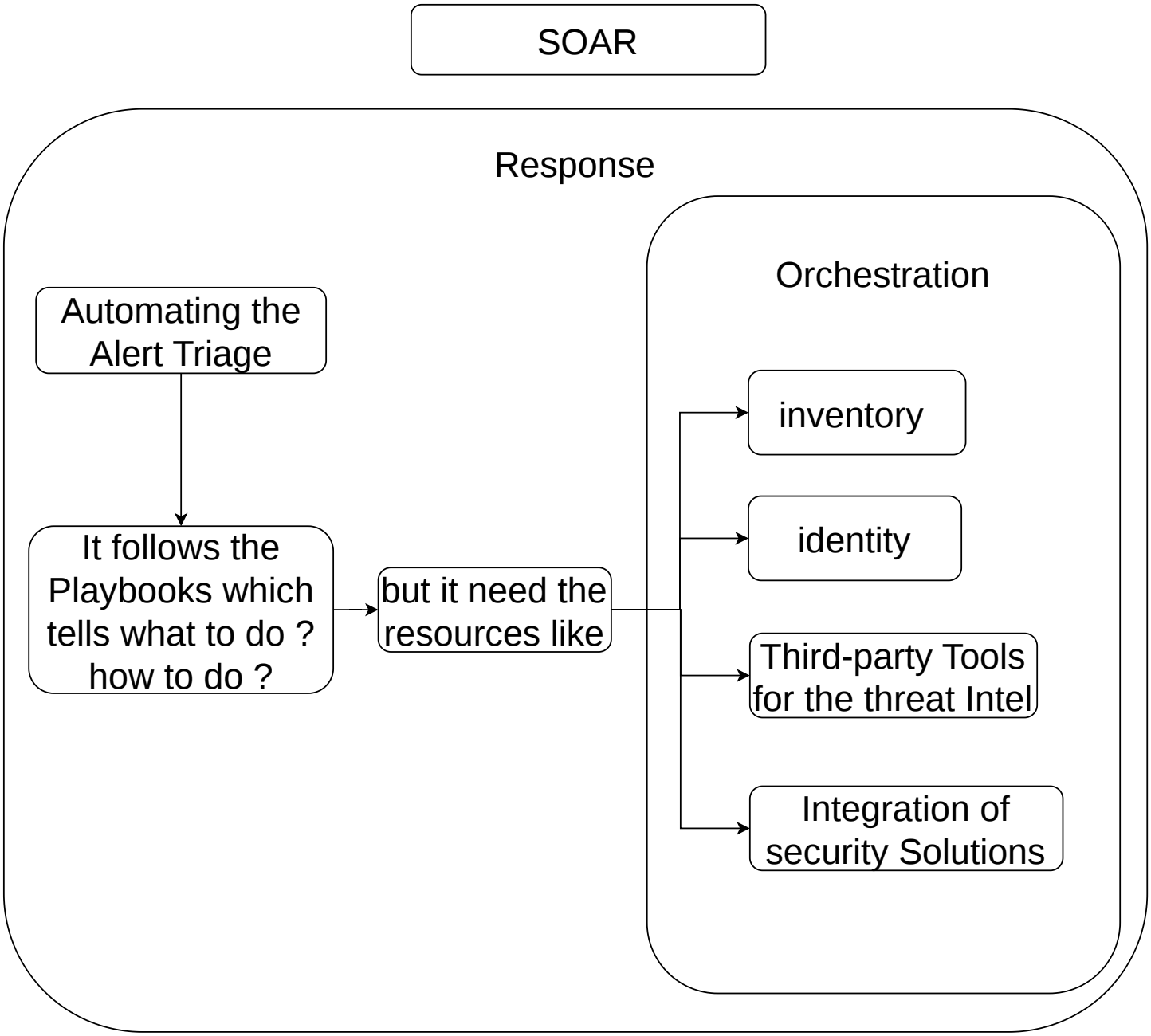
IOC(Indicators of Comptomise)

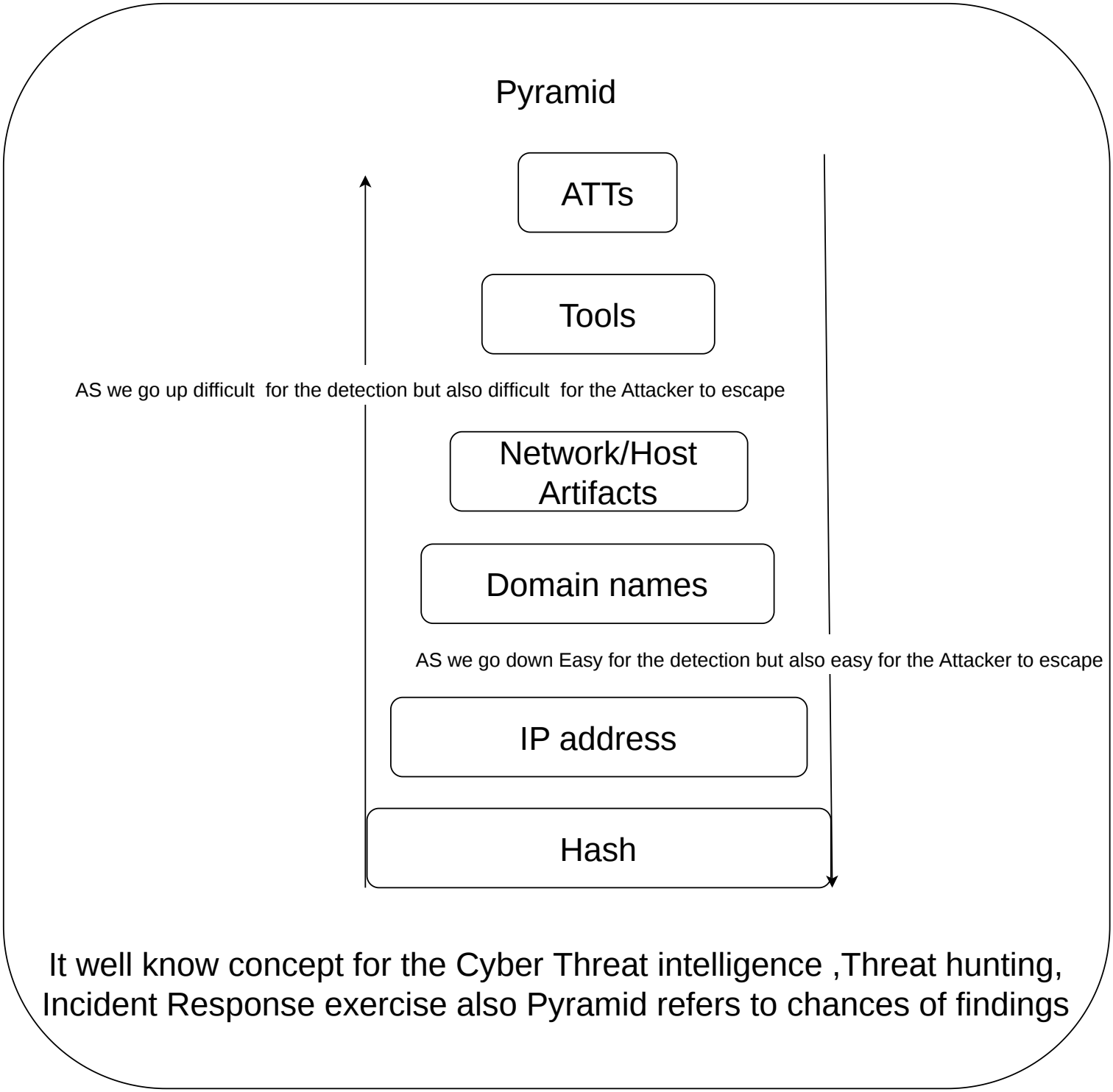
IOA(Indicators of Attack)

Detection Ruls

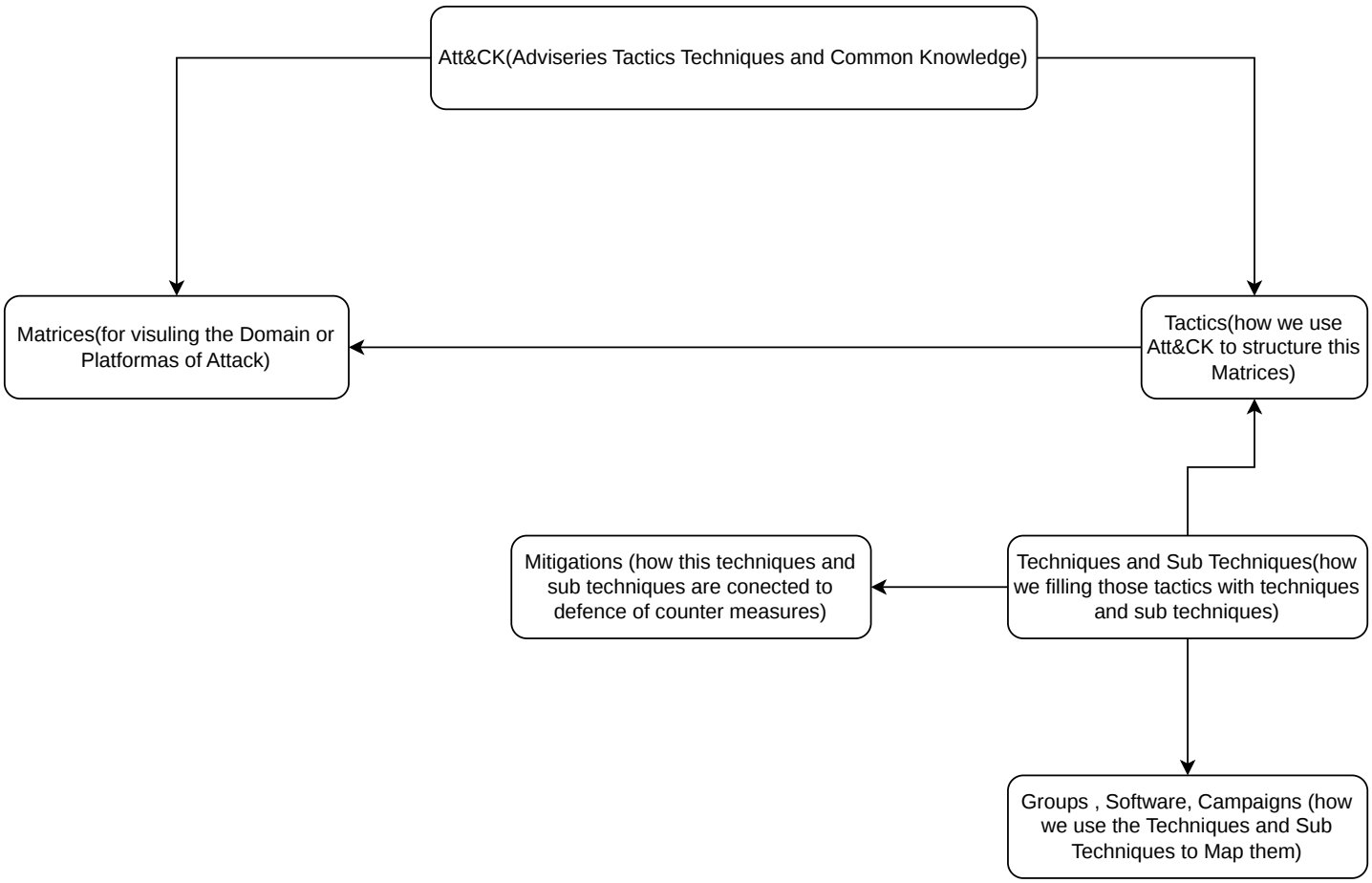

Splunk
Forwarder
Indexer
Search head
SPL


ELK(ElasticSearch_Logstach_Beats_Kibana
Beats
Logstach
ElasticSearch
Kibana
KQL(Kibana Query Language)
Free text Base search
Free text Base search
We can use Logical Operators AND ,OR, NOT
For
Visualization
use this as temples in the custom Dashboard
Custom Dashboard
Query

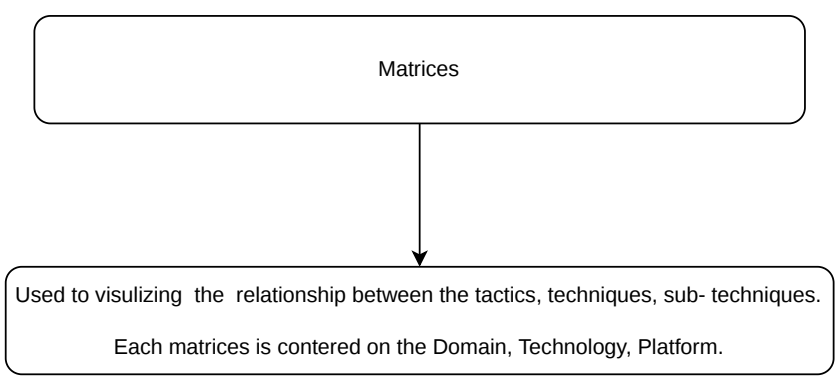

SOAR
Response
Orchestration
Automating the Alert Triage
It follows the Playbooks which tells what to do ? how to do ?
but it need the resources like
inventory
identity
Third-party Tools for the threat Intel
Integration of security Solutions



It well know concept for the Cyber Threat intelligence ,Threat hunting, Incident Response exercise also Pyramid refers to chances of findings



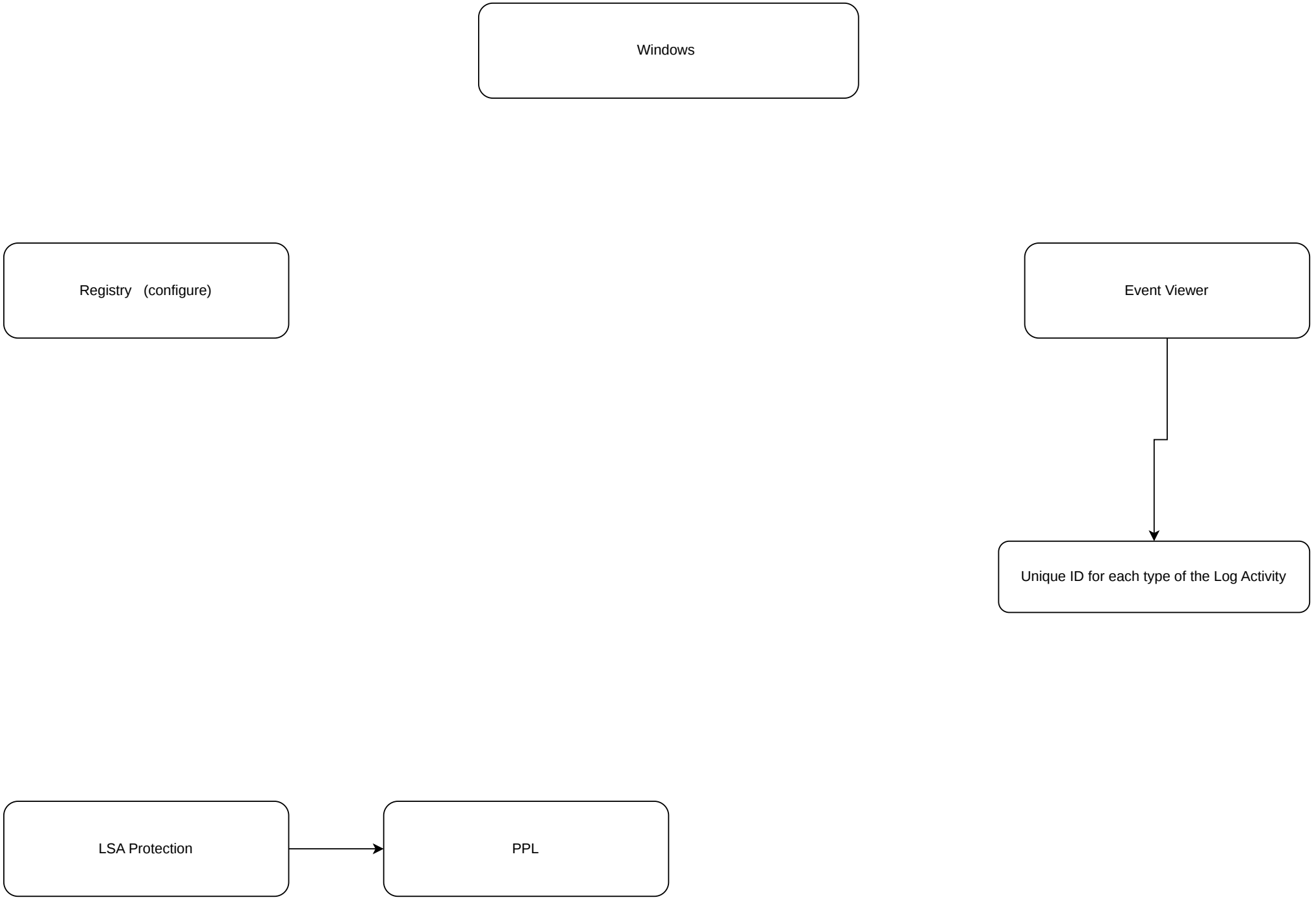
How Attack grows and evolves over time

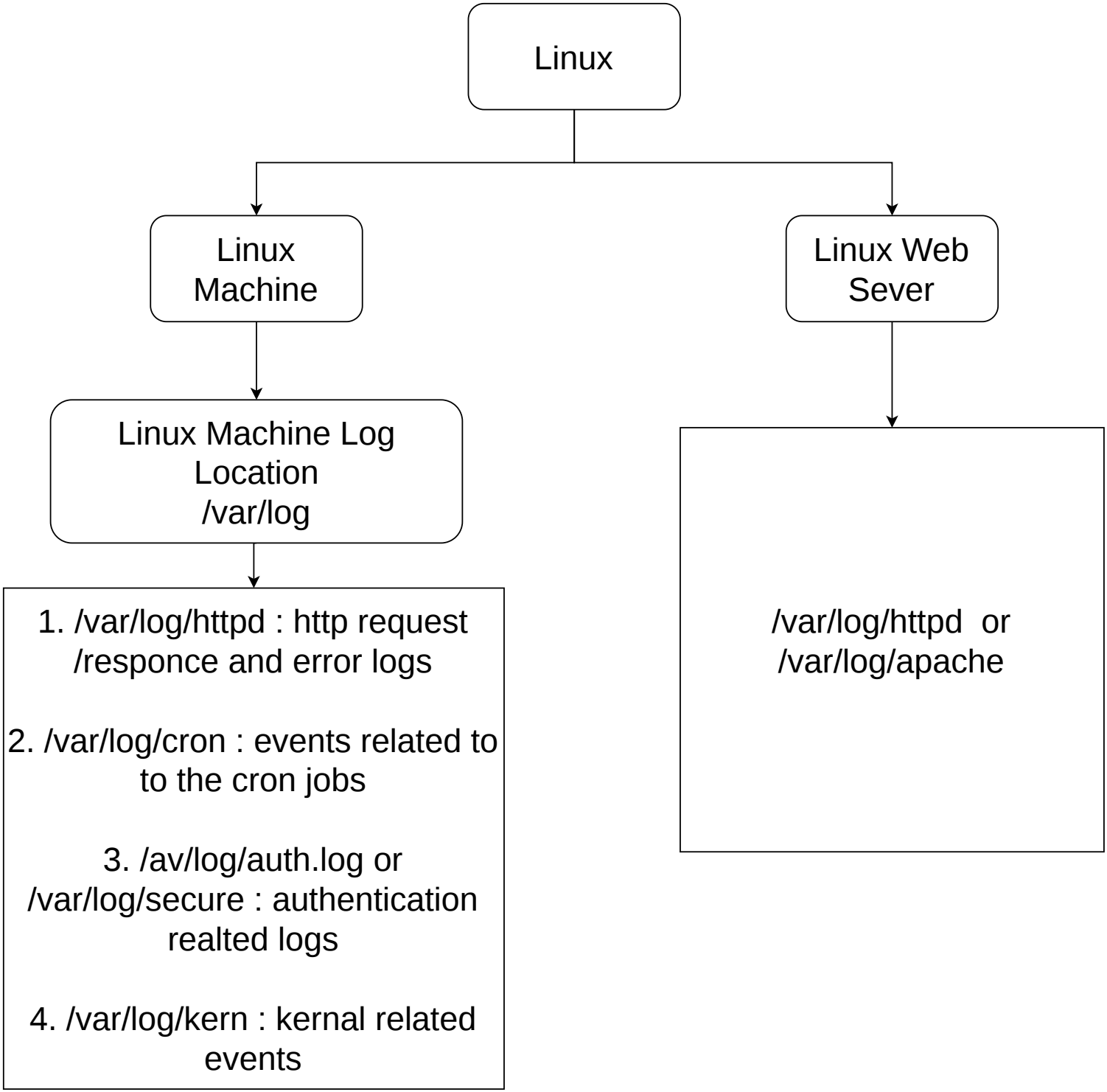


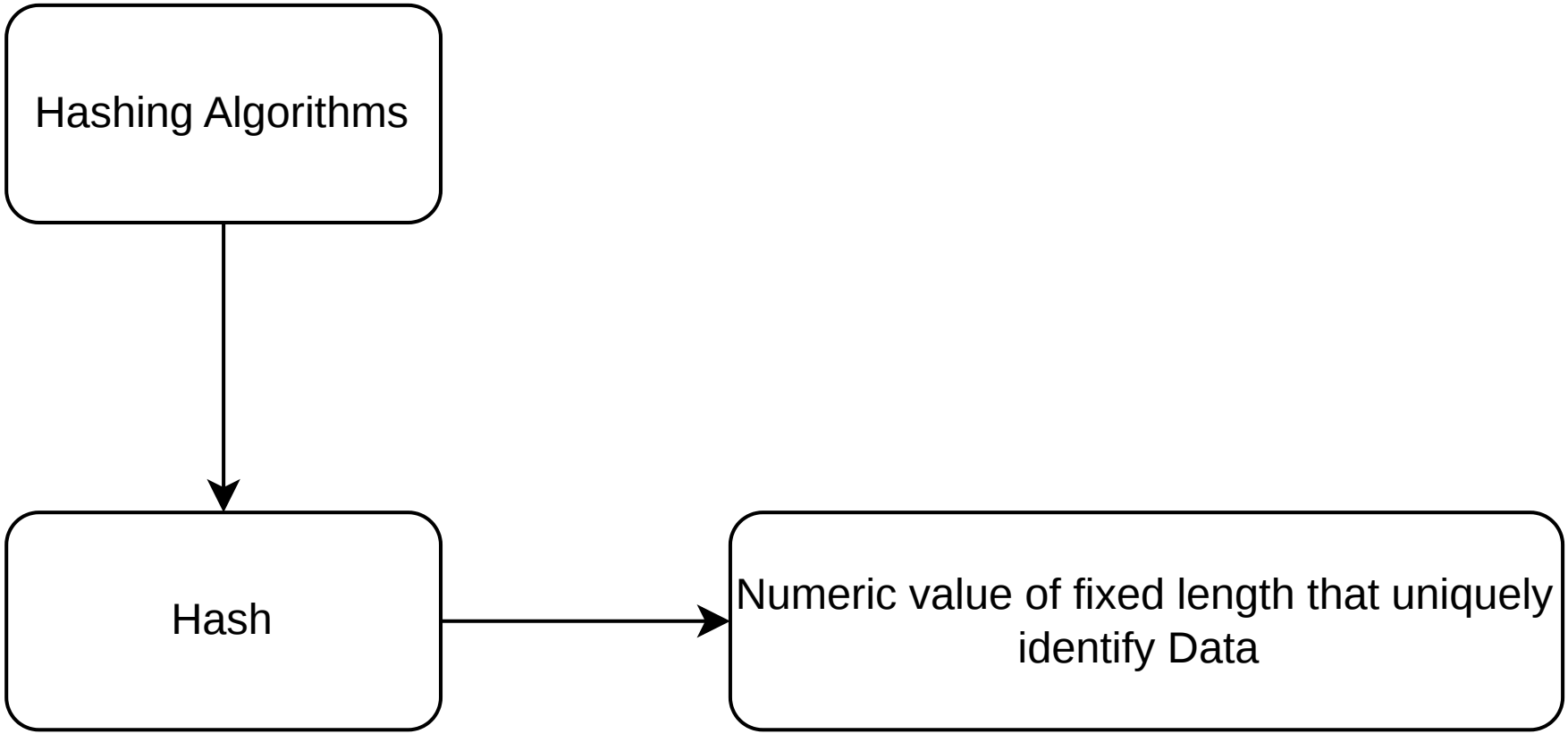
Cyber Kill Chain

Unified Kill Chain

CompTIA Penetration Testing Phases


Windows
Registry (configure)
Event Viewer
Unique ID for each type of the Log Activity
LSA Protection
PPL


Linux
Linux Machine
Linux Web Sever
Linux Machine Log Location /var/log
1. /var/log/httpd : http request /responce and error logs
2. /var/log/cron : events related to to the cron jobs
3. /av/log/auth.log or /var/log/secure : authentication realted logs
4. /var/log/kern : kernal related events
/var/log/httpd or /var/log/apache


Hashing Algorithms
Hash
Numeric value of fixed length that uniquely identify Data

Languages

Data Handling :
1.SQL

DaC(Detection as Code):

1. Sigma

2.Yara

Languages fo the Log Query:

1. SPL (Search Processing Language)

2. KQL (Kibana Query Language)

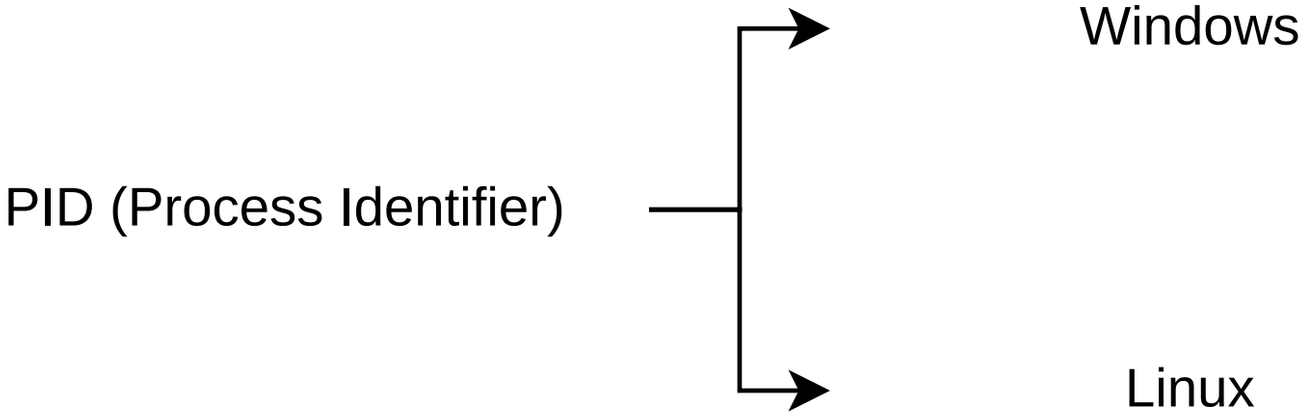
3. KQL (Kusto Query Language)

4. FQL (Falcon Query Language)

Programing :

1. python

purple-team



what is ASN ?

MITRE ATT&CK Navigator

Social Engrineering

Phishing

Email Phishing

Email Address Anatomy

username

@

domain.name

Protocal involed during transition

SMTP

DNS(to find and conform the Rescivers)

IMAP

POP3

Indide Email

Email header

From

To

Subject

Date and time

Email Body